

CYBER SECURE SOLUTIONS

Gestion d'une attaque avancée par ransomware

Type: plan_reponse_ransomware

Date: 3/31/2025
Référence: Gestion de crise cyber
Destinataire: Paul

****PLAN DE RÉPONSE À UNE ATTAQUE PAR RANSOMWARE****

****Domaine : Gestion de crise cyber****

****Scénario : Gestion d'une attaque avancée par ransomware****

****Niveau de difficulté : Expert****

****Contact : Lorenzo Bertola****

****Destinataire : Paul****

Introduction

Ce document présente les informations techniques et contextuelles nécessaires pour gérer une attaque avancée par ransomware. L'objectif est de fournir une vue d'ensemble de la situation et des éléments à prendre en compte pour concevoir une réponse adaptée dans le cadre d'une crise cyber. Les décisions prises devront être alignées avec les politiques internes de gestion des incidents et les normes applicables en cybersécurité.

Contexte de l'incident

- ****Type d'attaque détectée**** : Ransomware avancé, potentiellement lié à un groupe APT (Advanced Persistent Threat).
- ****Vecteur d'infection**** : Probablement via un courriel de phishing contenant une pièce jointe malveillante ou un lien vers un site compromis.
- ****Symptômes observés**** :
 - Verrouillage de fichiers critiques sur plusieurs serveurs (extensions modifiées).
 - Messages de demande de rançon s'affichant sur les postes utilisateurs.
 - Dégradation des performances du réseau interne.
- ****Données affectées**** : Documents administratifs, fichiers de base de données, et sauvegardes réseau.
- ****Impact immédiat**** : Interruption des opérations métiers dans plusieurs départements clés.

Informations techniques

****Ransomware identifié**** : Selon les premiers indices, le ransomware pourrait être une variante d'un logiciel malveillant connu pour ses capacités avancées de chiffrement et de propagation latérale. Cette

variante utilise un algorithme de chiffrement asymétrique robuste (ex. RSA 4096 bits), rendant le déchiffrement sans clé privée pratiquement impossible.

****Comportement suspect** :**

- Le ransomware semble utiliser des techniques d'évasion avancées pour éviter les solutions de détection traditionnelles (ex. obfuscation de code, utilisation de processus légitimes pour masquer ses activités).
- Des connexions réseau inhabituelles vers des serveurs de commande et contrôle (C2) ont été identifiées.

****Indicateurs de compromission (IoC)** :**

- Processus exécutés : `encryptor.exe`, `cmd.exe` avec paramètres de suppression de journaux.
- Fichiers créés : `README\_FOR\_DECRYPTION.txt`, fichiers avec extensions spécifiques (`.encrypted`, `.lock`).
- Adresses IP suspectes : 192.168.X.X pour propagation latérale ; connexions externes vers 203.0.113.X (C2).

Points critiques à considérer

1. ****Évaluation des impacts** :**

- Identifier les systèmes critiques touchés (priorité haute).
- Évaluer la portée de la compromission (étendue du chiffrement des données).

2. ****Communication interne et externe** :**

- Informer les parties prenantes internes sans générer de panique.
- Préparer une stratégie de communication externe (en cas de divulgation publique).

3. ****Protocole de confinement** :**

- Isoler les systèmes infectés du réseau pour éviter toute propagation.
- Identifier et désactiver les connexions suspectes vers les serveurs C2.

4. ****Analyse légaliste** :**

- Vérifier les obligations légales (RGPD, NIS, etc.) en cas de fuite de données.
- Considérer les implications légales de tout paiement de rançon (si envisagé).

Historique et références utiles

- ****Incident similaire**** : En 2021, une attaque par le ransomware "REvil" a paralysé une grande entreprise européenne pendant 10 jours. Les attaquants avaient utilisé des vulnérabilités non corrigées pour pénétrer le réseau.

- ****Rapport MITRE ATT&CK**** : Techniques utilisées par les ransomwares avancés incluent T1486 (Chiffrement des données), T1562.001 (Désactivation des outils de sécurité), et T1021.002 (Utilisation de comptes valides pour propagation latérale).

- ****Article de référence**** : "Advanced Ransomware Techniques: Trends in 2023", publié par SANS Institute.

Questions ouvertes à explorer

- Quels outils et techniques peuvent être utilisés pour identifier le point d'entrée initial du ransomware ?
- Comment gérer la récupération des données sans compromettre leur intégrité ?
- Quels mécanismes de résilience peuvent être mis en place pour éviter une attaque similaire à l'avenir ?

****Contact****

Pour toute question ou clarification, contactez Lorenzo Bertola (Service Cyber, poste : 1234, email : lbertola@entreprise.com).
